

ZEKRO

AUTONOMOUS RED TEAM AUDIT

// EXECUTIVE SECURITY INTELLIGENCE REPORT

[!] ACTIVE EXPLOITATION: ENABLED (LETHAL MODE)

Objetivo: kailu.travel
Fecha: 5/23/2026, 3:56:40 PM
Duración: 355s
Report ID: scan_1779569800958_tda988

Resumen Ejecutivo

El motor ofensivo Zekro ha finalizado la auditoría automatizada sobre el objetivo indicado. Se ha recopilado inteligencia técnica y se han identificado un total de 21 vectores de riesgo.

5

CRÍTICOS

1

ALTOS

5

MEDIOS

10

BAJOS / INFO

Inteligencia de Amenazas y Hallazgos

[CRÍTICO] Ruta Sensible Expuesta

Módulo: exposed_path | Objetivo Afectado: /.env

Identificador CVE: CWE-200

Análisis de Riesgo y Contexto de Negocio:

https://kailu.travel/.env returned HTTP 200. This path should not be publicly accessible.

[Impacto Real]: Se descubrieron rutas internas del servidor accesibles públicamente: paneles de administración, endpoints de debug, archivos de log o interfaces de gestión. Los atacantes acceden directamente a funcionalidades privilegiadas sin necesidad de autenticación.

Estrategia de Remediación (Playbook):

Block access to /.env in your web server config.

[CRÍTICO] Ruta Sensible Expuesta

Módulo: exposed_path | Objetivo Afectado: /.git/config

Identificador CVE: CWE-538

Análisis de Riesgo y Contexto de Negocio:

https://kailu.travel/.git/config returned HTTP 200. This path should not be publicly accessible.

[Impacto Real]: Se descubrieron rutas internas del servidor accesibles públicamente: paneles de administración, endpoints de debug, archivos de log o interfaces de gestión. Los atacantes acceden directamente a funcionalidades privilegiadas sin necesidad de autenticación.

Estrategia de Remediación (Playbook):

Block access to /.git/config in your web server config.

[CRÍTICO] Ruta Sensible Expuesta

Módulo: exposed_path | Objetivo Afectado: /actuador/env

Análisis de Riesgo y Contexto de Negocio:

https://kailu.travel/actuador/env returned HTTP 200. This path should not be publicly accessible.

[Impacto Real]: Se descubrieron rutas internas del servidor accesibles públicamente: paneles de administración, endpoints de debug, archivos de log o interfaces de gestión. Los atacantes acceden directamente a funcionalidades privilegiadas sin necesidad de autenticación.

Estrategia de Remediación (Playbook):

Block access to /actuador/env in your web server config.

[CRÍTICO] Ruta Sensible Expuesta

Módulo: exposed_path | Objetivo Afectado: /wp-config.php.bak

Identificador CVE: CWE-530

Análisis de Riesgo y Contexto de Negocio:

https://kailu.travel/wp-config.php.bak returned HTTP 200. This path should not be publicly accessible.

[Impacto Real]: Se descubrieron rutas internas del servidor accesibles públicamente: paneles de administración, endpoints de debug, archivos de log o interfaces de gestión. Los atacantes acceden directamente a funcionalidades privilegiadas sin necesidad de autenticación.

Estrategia de Remediación (Playbook):

Block access to /wp-config.php.bak in your web server config.

[CRÍTICO] AI Strategist: OPPLAN Generated

Módulo: ai_opplan | Objetivo Afectado: OPPLAN

Análisis de Riesgo y Contexto de Negocio:

Anomalía detectada en ai_opplan.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Evidencia Técnica del Vector (PoC):

```
#!/bin/bash

# PoC for Multiple Exposed Sensitive Paths - kailu.travel
# This script demonstrates information disclosure vulnerabilities

TARGET="https://kailu.travel"
echo "Testing exposed sensitive paths on $TARGET"
echo "===== "

# Test 1: Environment file exposure
echo "[1] Testing .env file exposure:"
curl -s -o /dev/null -w "Status: %{http_code}\n" "$TARGET/.env"

# Test 2: Git repository exposure
echo "[2] Testing .git/config exposure:"
curl -s -o /dev/null -w "Status: %{http_code}\n" "$TARGET/.git/config"

# Test 3: Apache server-status exposure
echo "[3] Testing server-status exposure:"
curl -s -o /dev/null -w "Status: %{http_code}\n" "$TARGET/server-status"

# Test 4: Spring Boot Actuator exposure
echo "[4] Testing actuator/env exposure:... [TRUNCATED STRING]"
```

Estrategia de Remediación (Playbook):

Review the generated strategic plan and immediately patch the listed attack vectors.

[ALTO] Ruta Sensible Expuesta

Módulo: exposed_path | Objetivo Afectado: /server-status

Identificador CVE: CWE-200

Análisis de Riesgo y Contexto de Negocio:

https://kailu.travel/server-status returned HTTP 200. This path should not be publicly accessible.

[Impacto Real]: Se descubrieron rutas internas del servidor accesibles públicamente: paneles de administración, endpoints de debug, archivos de log o interfaces de gestión. Los atacantes acceden directamente a funcionalidades privilegiadas sin necesidad de autenticación.

Estrategia de Remediación (Playbook):

Block access to /server-status in your web server config.

[MEDIO] DNSSEC No Habilitado

Módulo: NO_DNSSEC | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

DNSSEC not enabled. Domain is vulnerable to DNS spoofing/cache poisoning attacks.

[Impacto Real]: La zona DNS carece de firma criptográfica. Un atacante con acceso a nivel de red (ISP, Wi-Fi corporativo) puede interceptar consultas DNS y redirigir el tráfico hacia servidores bajo su control, clonando la interfaz para robar credenciales de forma masiva e indetectable.

Estrategia de Remediación (Playbook):

Activar DNSSEC en el registrador del dominio. Verificar propagación con herramientas como DNSViz.

[MEDIO] DKIM No Detectado

Módulo: DKIM_NOT_DETECTED | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Cryptographic Signature Missing (DKIM). Domain payload authenticity cannot be mathematically verified.

[Impacto Real]: Los correos del dominio no llevan firma criptográfica DKIM. Los servidores receptores no pueden verificar que el correo realmente fue enviado por la empresa. Los atacantes falsifican correos idénticos para phishing, fraude financiero y robo de datos de clientes.

Estrategia de Remediación (Playbook):

Generar par de claves DKIM, publicar la clave pública en DNS y configurar la firma automática en el servidor de correo.

[MEDIO] Ruta Sensible Expuesta

Módulo: exposed_path | Objetivo Afectado: /.DS_Store

Identificador CVE: CWE-538

Análisis de Riesgo y Contexto de Negocio:

https://kailu.travel/.DS_Store returned HTTP 200. This path should not be publicly accessible.

[Impacto Real]: Se descubrieron rutas internas del servidor accesibles públicamente: paneles de administración, endpoints de debug, archivos de log o interfaces de gestión. Los atacantes acceden directamente a funcionalidades privilegiadas sin necesidad de autenticación.

Estrategia de Remediación (Playbook):

Block access to /.DS_Store in your web server config.

[MEDIO] Vulnerabilidad DNS

Módulo: dns | Objetivo Afectado: kailu.travel

Análisis de Riesgo y Contexto de Negocio:

DNSSEC not enabled. Domain is vulnerable to DNS spoofing/cache poisoning attacks.

[Impacto Real]: La configuración DNS presenta debilidades: transferencia de zona habilitada, registros obsoletos, subdominios huérfanos o resolvers abiertos. Los atacantes usan esto para mapear toda la infraestructura, ejecutar subdomain takeover o lanzar ataques de amplificación DDoS.

Estrategia de Remediación (Playbook):

Enable DNSSEC for your domain.

[MEDIO] Detección de WAF/Firewall

Módulo: waf | Objetivo Afectado: https://kailu.travel

Análisis de Riesgo y Contexto de Negocio:

No Web Application Firewall was detected protecting this application.

[Impacto Real]: Se detectó la presencia (o ausencia) de un Web Application Firewall. Si no hay WAF, la aplicación está directamente expuesta a ataques automatizados (SQLi, XSS, bots). Si hay WAF pero está mal configurado, los atacantes pueden evadir sus reglas.

Estrategia de Remediación (Playbook):

Consider deploying a WAF (Cloudflare, AWS WAF, ModSecurity) to protect against common web attacks.

[BAJO] SPF FAILURE

Módulo: SPF_FAILURE | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Authentication Failure: Missing SPF. Critical risk of Corporate Spoofing & Phishing.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Estrategia de Remediación (Playbook):

1. Revisar la configuración del componente SPF_FAILURE.
2. Validar manualmente la existencia y el riesgo real de la vulnerabilidad.
3. Aplicar medidas de mitigación o marcaje como falso positivo según corresponda.

[BAJO] DMARC Débil o Ausente

Módulo: DMARC_FAILURE | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Missing DMARC Policy. Domain is entirely unprotected against Direct-Domain Spoofing.

[Impacto Real]: Sin política DMARC estricta, los servidores de correo no saben qué hacer con emails falsificados. Los atacantes lanzan campañas masivas de phishing usando el dominio de la empresa sin que el equipo de seguridad reciba ninguna alerta.

Estrategia de Remediación (Playbook):

Implementar DMARC progresivamente: p=none (monitoreo) !' p=quarantine !' p=reject.

[BAJO] MX RECORD MISSING

Módulo: MX_RECORD_MISSING | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Mail Exchanger (MX) routing missing. Domain incapable of receiving telemetry or correspondence.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Estrategia de Remediación (Playbook):

1. Revisar la configuración del componente MX_RECORD_MISSING.
 2. Validar manualmente la existencia y el riesgo real de la vulnerabilidad.
 3. Aplicar medidas de mitigación o marcaje como falso positivo según corresponda.
-

[BAJO] Cabecera de Seguridad Faltante

Módulo: missing_header | Objetivo Afectado: <https://kailu.travel>

Análisis de Riesgo y Contexto de Negocio:

Inadequate defense-in-depth: Controls which resources can be loaded.

[Impacto Real]: Cabeceras HTTP críticas como Content-Security-Policy, X-Frame-Options o Strict-Transport-Security no están presentes. Sin ellas, el navegador del usuario no tiene instrucciones de seguridad y queda vulnerable a XSS, clickjacking y downgrade attacks.

Estrategia de Remediación (Playbook):

Deploy "content-security-policy" header at edge/proxy to mitigate client-side exploitation vectors.

[BAJO] Cabecera de Seguridad Faltante

Módulo: missing_header | Objetivo Afectado: <https://kailu.travel>

Análisis de Riesgo y Contexto de Negocio:

Inadequate defense-in-depth: Legacy XSS filter. Modern browsers use CSP instead, but still good practice.

[Impacto Real]: Cabeceras HTTP críticas como Content-Security-Policy, X-Frame-Options o Strict-Transport-Security no están presentes. Sin ellas, el navegador del usuario no tiene instrucciones de seguridad y queda vulnerable a XSS, clickjacking y downgrade attacks.

Estrategia de Remediación (Playbook):

Deploy "x-xss-protection" header at edge/proxy to mitigate client-side exploitation vectors.

[BAJO] Fuga de Información

Módulo: info_leak | Objetivo Afectado: <https://kailu.travel>

Análisis de Riesgo y Contexto de Negocio:

The Server header reveals your web server software and version.

[Impacto Real]: El servidor expone datos internos: versiones de software, rutas del filesystem, stack traces de error o archivos de configuración. Los atacantes recopilan esta información para diseñar ataques precisos contra las versiones y componentes específicos identificados.

Estrategia de Remediación (Playbook):

Remove or obfuscate the Server header.

[INFO] Supabase Anon Key & URL Exposed in Frontend

Módulo: js_secret_exposure | Objetivo Afectado: https://kailu.travel/assets/index-Bc9NP_Zj.js

Análisis de Riesgo y Contexto de Negocio:

Anomalía detectada en js_secret_exposure.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Estrategia de Remediación (Playbook):

Verify that robust RLS policies are enforced on all Supabase tables. No action needed if RLS is configured correctly.

[INFO] Reconocimiento DNS Exitoso

Módulo: dns_info | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

3 record types resolved. Grade: A

[Impacto Real]: El escaneo DNS reveló información detallada sobre la infraestructura: servidores de correo, subdominios internos, registros TXT con tokens de verificación. Los atacantes usan esta inteligencia para planificar ataques dirigidos contra servicios específicos.

Estrategia de Remediación (Playbook):

Informational — review DNS configuration for best practices.

[INFO] Calificación TLS Baja

Módulo: tls_grade | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Protocol: N/A, Cipher: N/A

[Impacto Real]: La configuración TLS del servidor recibió una calificación insuficiente. Esto indica múltiples debilidades combinadas: protocolos obsoletos, cifrados débiles y configuración subóptima que en conjunto facilitan la interceptación del tráfico cifrado.

Estrategia de Remediación (Playbook):

Aim for grade A or higher.

[INFO] Breach Intel Engine Error

Módulo: error | Objetivo Afectado: HavelBeenPwned Intel

Análisis de Riesgo y Contexto de Negocio:

Anomalía detectada en error.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Estrategia de Remediación (Playbook):

Check API keys or rate limiting.

Conclusión Ejecutiva y Calificación de Riesgo

100

RISK SCORE /100

CRÍTICO

DESGLOSE DE IMPACTO

% 5 hallazgos críticos !' Explotación inmediata posible

% 1 hallazgos altos !' Compromiso probable sin remediación

% 5 hallazgos medios !' Vectores de escalamiento lateral

% 10 hallazgos bajos !' Endurecimiento recomendado

Total: 21 vectores identificados

La infraestructura evaluada presenta un nivel de exposición CRÍTICO. Se han identificado vectores que permiten compromiso directo con impacto inmediato en la confidencialidad, integridad y disponibilidad de los activos digitales. Se recomienda activar un plan de respuesta a incidentes y priorizar la remediación de los hallazgos críticos y altos en las próximas 24-48 horas.

Matriz de Priorización de Remediación

0-48 horas	Críticos	Vectores con explotación activa o impacto directo en datos sensibles.
1-2 semanas	Altos	Vulnerabilidades con exploits públicos disponibles o acceso privilegiado.
30 días	Medios	Configuraciones incorrectas y vectores de escalamiento.
Trimestral	Bajos / Info	Mejoras de endurecimiento y mejores prácticas.

Este reporte fue generado de forma automatizada por el motor ofensivo Zekro. Los hallazgos reflejan el estado de la infraestructura al momento de la evaluación. Se recomienda reevaluar después de cada ciclo de remediación.